

appsec-review

Executive design and operations overview

VERSION**0.4****STATUS****Qualified nominal path****DATE**

2026-09-27

OWNER

W. Sollers

AUDIENCE Security leadership, engineering leaders and review operators**BOTTOM LINE**

appsec-review turns an authorized repository snapshot into traceable security evidence and an evidence-backed draft report. It now includes component-aware search, offline vulnerability matching, binary hardening, reconciled threat modeling, multi-language SAST, OWASP publication and synthesis publication. Four integration gates remain before the first final real-target report: automatic full-review plan/dispatch, automatic OWASP dispatch-fact derivation, one retained real accepted end-to-end run, and human final authorization.

LIFECYCLE JOBS**66**

Declared in the current graph

SEARCH PLANES**2**

Text/semantic plus structural

DECISION ROLES**3**

Red, blue, independent verifier

OPEN GATES**4**

Automation, live chain and sign-off

What leadership should know

- Results are evidence-first: every consequential claim must resolve to immutable accepted input.
- A missing check lowers coverage; it never becomes a clean result.
- Tools and reference data are pinned, and scanning is offline by default.
- The produced report is presently a qualified draft until a human authorizes final publication.

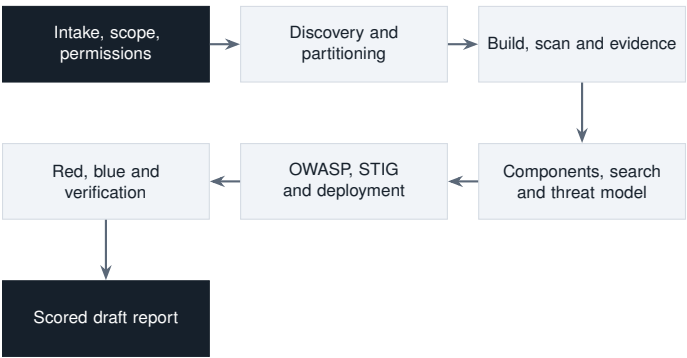
Contents

1	Purpose and operating boundary	2
2	How a review moves through the system	3
3	Project partitioning and component model	3
4	Static evidence gathered and seeded	3
5	Search architecture and cross-references	4
6	Threat model and control work	4
7	Red, blue and verifier rendezvous	4
8	Reporting and publication	4
9	Current readiness	5
10	How to operate and configure	5
11	Risk and next decisions	6
A	Authority and retained artifacts	6
B	Revision history	6

1 Purpose and operating boundary

The system reviews supplied source, build metadata, binaries, images, IaC, dependencies, configuration, documentation and static exports. Local compilation is allowed to recover compiler semantics. The baseline does not probe production, call live cloud APIs, run authenticated DAST or exercise network services. Build scripts are treated as hostile and run in a disposable, no-network, least-privilege worker. Only allowlisted, hashed artifacts cross back into the trusted evidence store.

2 How a review moves through the system



Each job receives explicit, bounded input and emits an immutable attempt with status, coverage, permission and lineage. Accepted pointers select the current attempt. Downstream jobs dereference and revalidate hashes rather than trusting copied prose. The graph allows independent evidence families to run concurrently, then joins them at explicit rendezvous.

3 Project partitioning and component model

Repository discovery separates independently buildable projects, vendored areas, generated code, deployment surfaces and operational material. Component characterization converts accepted discovery and evidence into stable component IDs, ownership, languages, trust boundaries, data flows, build units and coverage. This component map is the shared scope key for threat modeling, standards worklists, analysis assignments and report rollups.

The full-review input assembler revalidates a supplied closed launch plan and produces bounded requests for vendor, dependency and analysis families. Automatic derivation of the complete plan from the component map, and automatic dispatch of every request, are the first remaining integration gate.

4 Static evidence gathered and seeded

FAMILY	REPRESENTATIVE RETAINED EVIDENCE
Source	Language SAST including Go, Java and PHP; secrets; mobile; config and IaC findings.
Build/native	Compile database, build units, LLVM IR, Joern CPG/AST, symbols, tests, memory leads and ELF hardening.
Supply chain	Image inventory, SBOMs, licences, lifecycle/EOL signals, offline SCA matches and CVE reachability.
Context	Project/operations discovery, documents, APIs, standards snapshots and threat-model inputs.

Reference data is synchronized outside the engagement flow and then bound by digest and timestamp. This includes Grype/OSV vulnerability data and standards sources. The engagement allows a configured staleness range; absent or over-age data is reported as a gap. No live lookup is added to the main flow to make a result appear complete.

5 Search architecture and cross-references

Two search planes serve different questions. The full-text and LanceDB semantic projections find literal text, configuration, documentation and conceptually related evidence. Joern CPG/AST and LLVM IR projections answer structural questions about calls, symbols, types, control/data flows and memory operations. Exported records are bounded and preserve source locations and build identity.

Cross-reference edges connect repository partitions, components, files, symbols, build units, binaries, dependencies, controls, threat hypotheses, claims, findings and report citations. This lets a reviewer move from a report statement back to the exact code or tool evidence, or from one component outward to all applicable checks and unresolved gaps.

6 Threat model and control work

L6A produces an initial DFD and STRIDE hypothesis set from the characterized components. L6B reconciles that model with accepted evidence, preserves conflicts and emits explicit model coverage. Both stages are executable and qualified. A target's report may cite only that target's accepted reconciliation.

OWASP, STIG/SRG and deployment hardening remain distinct processes:

1. The OWASP T03–T14 chain routes ASVS/MASVS controls by component, validates bounded work and publishes deterministic pages, a status matrix, gaps and candidate routes. It is qualified; automatic derivation of trusted dispatch facts remains open.
2. STIG/SRG tailoring selects platform-specific controls and publishes a validation worklist.
3. Deployment hardening consumes the tailored worklist plus static deployment evidence. Its observations are not a compliance certification and do not substitute for control validation.

7 Red, blue and verifier rendezvous

The orchestrator gives each persona or tool member an immutable handoff, permission receipt and bounded assignment. Every expected member must reach a durable terminal state. Deterministic merge validates identity, contracts, citations and order, while retaining dissent. Evidence-qualified quorum applies evidence and independence thresholds.

Red team proposes attack hypotheses. Blue team attempts to refute, narrow or explain them. Independent verification alone can verify a claim. Scoring acts only on verified claims. Their communication occurs through typed, hash-bound artifacts and append-only claim decisions, not an uncontrolled shared chat. This preserves both the admission head and the later decision head.

8 Reporting and publication

The synthesis publication worker consumes exact accepted inputs and produces report JSON and Markdown, coverage appendix, evidence trace index, publication manifest, LaTeX presentation input, HTML and render manifests. The fixture-qualified result is correctly labeled `DRAFT_EVIDENCE_BACKED`; it can be `OK_WITH_GAPS` and still be an honest successful publication.

The final gate must revalidate all inputs and presentation hashes, require completion accounting, and receive human authorization. It may not silently transform a fixture, sample or draft into a final assessment.

9 Current readiness

CAPABILITY	STATUS	MEANING
Joern CPG/AST, LLVM IR and search	● Qualified	Accepted producer to indexed, cited query path exists.
Offline vulnerability matching	● Qualified	Seeded snapshot, bounded age and no-network matching retained.
Native binary hardening	● Qualified	Real accepted ELF routed from build to Checksec.
Threat reconciliation	● Qualified	L6A plus executable L6B with conflict and coverage output.
Go, Java and PHP SAST	● Qualified	Pinned tools produced cited leads in a live qualification.
OWASP T03–T14 publication	● Qualified	Deterministic pagination, matrix, gaps and routes retained.
Synthesis publication	● Qualified draft	Hash-bound LaTeX/HTML draft path retained.
Automatic full-review plan and dispatch	● Open	Assembler validates a supplied plan; derivation/dispatch is pending.
Automatic OWASP dispatch facts	● Open	Trusted facts are still supplied at the integration boundary.
Real accepted end-to-end report	● Open	Fixture qualifications do not replace one complete target run.
Human final publication	● Open	Draft remains final=false and human_signoff=false.

10 How to operate and configure

Operators stage the engagement definition, permission grant, target snapshot and any supplied discovery records; validate graph parity and pins; start Dagster; launch `full_review`; monitor accepted attempts and coverage; then launch `synthesis_report`. Configuration changes belong in versioned registry templates, contracts, image pins or snapshot policy, not in target content or ad hoc report edits. The operator guide contains commands and stop conditions.

11 Risk and next decisions

RISK	CONTROL AND NEXT ACTION
Incomplete coverage looks clean	Coverage denominators and gaps are mandatory; qualify the real accepted end-to-end run.
Reasoning overstates a scanner hit	Red/blue/verifier separation, cited evidence and verified-only scoring.
Reference data becomes stale	Out-of-band sync, digest/time binding and explicit age policy.
Automation dispatches wrong scope	Derive the closed launch plan from the accepted component map and retain reviewed dispatch receipts.
Draft published as final	Human authorization and fail-closed final-publication validation.

A Authority and retained artifacts

The machine-readable job graph, design-parity manifest, registry templates/contracts and accepted run artifacts are authoritative. The generated job catalog describes the complete topology. This document summarizes the interaction model for leadership; it does not grant completion credit.

B Revision history

VERSION	DATE	AUTHOR	CHANGE
0.4	2026-09-27	W. Sollers	Updated for qualified analysis, OWASP and synthesis publication; recorded four remaining gates.
